Website Security Assessment Report

1.Nmap findings first

2.Then OWASP ZAP results

3.Plus Dev Tools-based observations specific to the target

Vulnerability Assessment Report :

Target: demo.testfire.net

Assessment Type: Read-only Security Analysis

Tools Used : Nmap, OWASP ZAP, Browser Developer Tools

1. Executive Summary :

A comprehensive security assessment was performed on the target application to identify exposed services, misconfigurations, and client-side weaknesses.

The analysis combined:

1. Network-level scanning (Nmap)
2. Passive web vulnerability scanning (OWASP ZAP)
3. manual inspection using browser developer tools

The results indicate that the system exposes multiple services and lacks several critical security protections. While the application is intentionally vulnerable, the findings reflect real-world security risks if such issues exist in production environments.

2. Network & Service Analysis (Nmap Findings)

2.1 Open Ports & Services

The scan identified the following open ports:

Port 80 (HTTP) – unencrypted communication

Port 443 (HTTPS) – encrypted communication available

Port 8080 (HTTP) – additional web interface

Identified Services

Web Server: Apache Tomcat (Coyote JSP Engine 1.1)

Application: Altoro Mutual

2.2 Identified Issues

1.Unsecured HTTP Communication

Risk Level: High

Issue : Traffic over port 80 is not encrypted.

Why It Matters : Attackers can intercept sensitive data.

Risk: Man-in-the-Middle (MITM) attacks

Remediation: 1.Force HTTPS redirection

2.Disable HTTP if not required

2.Multiple Open Ports :

Risk Level: High

Issue: Ports 80, 443, and 8080 are accessible.

Why It Matters: Each open port increases attack surface.

Risk: Unauthorized access points

Remediation: 1.Close unused ports

2.Restrict access using firewall rules

3.Server Information Disclosure :

Risk Level: Medium

Issue: Server version details are visible.

Why It Matters: Helps attackers identify known exploits.

Risk: Targeted attacks

Remediation: 1.Hide server banners

2.Disable version exposure

4. Potential SSL/TLS Misconfiguration :

Risk Level: Medium–High

Issue: Certificate configuration appears weak or improperly configured.

Why It Matters: Reduces trust in encrypted communication.

Risk: Compromised secure sessions

Remediation: 1.Use valid SSL certificates

2.Enforce modern TLS versions

5.Vulnerable Application Exposure

Risk Level: High

Issue: The application (Altoro Mutual) is intentionally insecure.

Why It Matters: Contains known vulnerabilities such as:

1.SQL Injection

2.Cross-Site Scripting (XSS)

3.Weak authentication

Risk: Complete system compromise

Remediation: 1.Avoid using vulnerable apps in production

2.Replace with secure implementations

3.conduct secure code reviews

```
[user@parrot]-[~]
└─$ nmap -A demo.testfire.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-18 00:20 UTC
Failed to resolve "demo.testfire.com".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.45 seconds
[user@parrot]-[~]
└─$ nmap -A demo.testfire.net
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-18 00:22 UTC
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.34s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE    VERSION
80/tcp   open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
443/tcp  open  ssl/https?
|_ssl-date: 2026-04-18T00:30:21+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
8080/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 499.11 seconds
[user@parrot]-[~]
└─$
```

3. Client-Side & Dev Tools Analysis

Manual inspection using browser Developer Tools revealed additional weaknesses:

3.1 Sensitive Information in HTML Source:

Risk Level: Low

Issue: Comments in HTML expose internal references (e.g., admin hints, developer notes).

Why It Matters: Provides attackers with reconnaissance data.

Risk: Improved attack planning

Fix: 1.Remove comments before deployment

2.Avoid exposing internal logic

3.2 Insecure Form Handling :

Risk Level: Medium

Issue: Forms lack visible protections such as CSRF tokens and input validation hints.

Why It Matters: Forms are primary attack vectors.

Risk: 1.Data manipulation, 2. injection attacks

Fix: 1.Implement server-side validation

2.Use CSRF protection

3.3 Session Cookie Weaknesses :

Risk Level: Low

Issue: Cookies lack proper attributes (SameSite , Secure).

Why It Matters: Weakens session protection.

Risk: Session hijacking

Fix: Http Set-Cookie: Secure; HttpOnly ; SameSite=Strict

3.4 JavaScript Exposure:

Risk Level: Low

Issue: Client-side scripts reveal endpoints and logic.

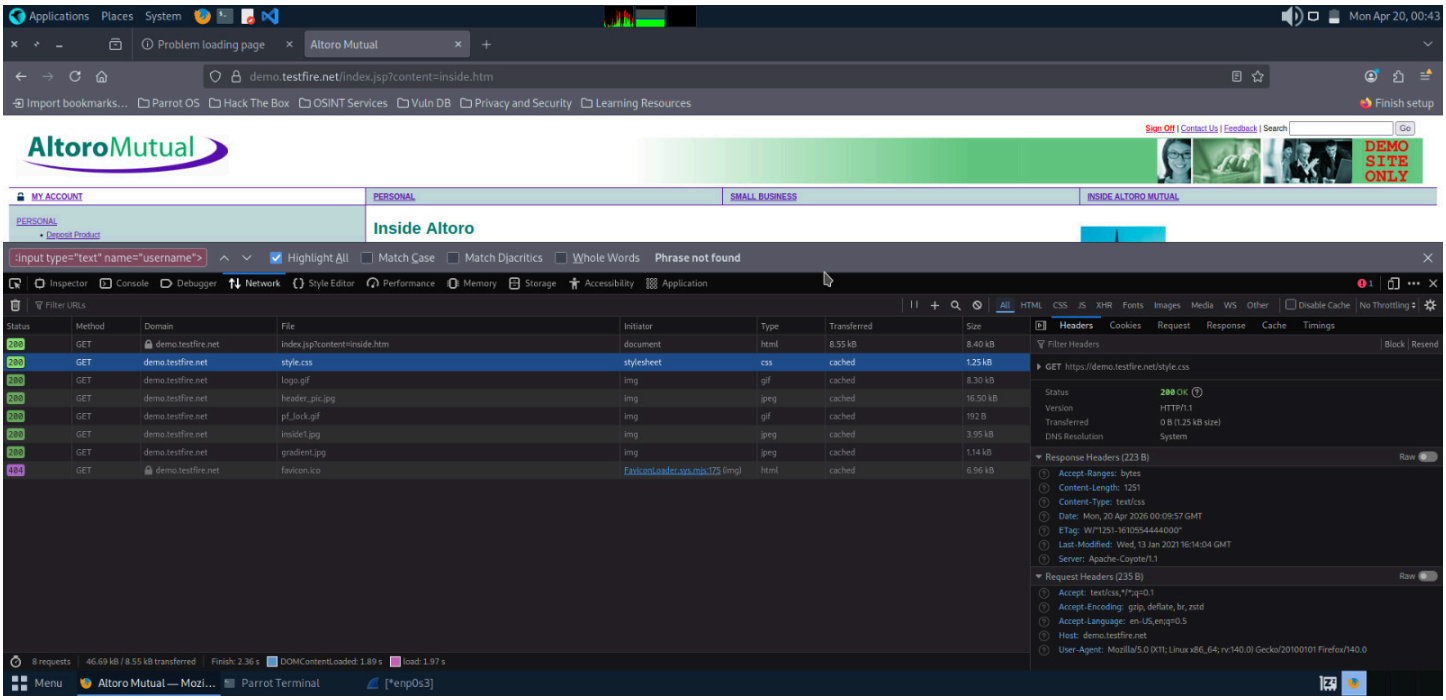
Why It Matters: Attackers can reverse engineer functionality.

Risk:

API abuse or manipulation

Fix: 1.Minimize exposed logic

2.Obfuscate sensitive scripts if needed



4. Web Application Vulnerabilities (OWASP ZAP Findings)

4.1 Absence of Anti-CSRF Tokens :

Risk Level: Medium

Issue: No CSRF tokens in requests.

Impact: Unauthorized actions via forged requests

Fix: 1.Implement CSRF tokens

2.Validate on every request

4.2 Missing Content Security Policy (CSP) :

Risk Level: Medium

Issue: CSP header not present.

Impact: Increased XSS risk

Fix: Http Content-Security-Policy: default-src 'self';

4.3 Missing Anti-Clickjacking Protection :

Risk Level: Medium

Issue: No iframe protection.

Impact: UI redressing attacks

Fix: Http X-Frame-Options: DENY

4.4 Cookie Without SameSite Attribute :

Risk Level: Low

Issue: Cookies sent in cross-site requests.

Impact: CSRF exposure

Fix: Use SameSite=Strict

4.5 Server Version Disclosure :

Risk Level: Low

Issue: Server reveals Apache-Coyote/1.1

Impact: Targeted exploitation

Fix: Hide version details

4.6 Missing Security Headers :

Risk Level: Low

Issue: Headers not implemented:

1. X-Content-Type-Options
2. HSTS

Impact: Browser-level vulnerabilities

Fix: Http X-Content-Type-Options: nosniff

Strict-Transport-Security: max-age=31536000;

4.7 Information Disclosure :

Risk Level: Informational

Issue: Sensitive comments and responses detected

Fix: Remove unnecessary exposure

4.8 Session Management Observed :

Risk Level: Informational

Issue: Session IDs detected

Fix: Ensure secure handling and expiration

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

```
<td valign="top" colspan="3" class="bb">
        <div class="fl" style="width: 99%;">

        <h1>Online Banking Login</h1>

        <!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Information Disclosure - Suspicious Comments

URL: https://demo.testfire.net/login.jsp
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: admin
CWE ID: 200
WASC ID: 13
Source: Passive (10027 - Information Disclosure - Suspicious Comments)
Input Vector:

Description:
The response appears to contain suspicious comments which may help an attacker. Note: Matches made within script blocks or files are against the entire content not only comments.

Other Info:
The following pattern was used: \bADMIN\b and was detected in the element starting with: "<!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->", see evidence field for the suspicious comment/snippet.

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Content Security Policy (CSP) Header Not Set

URL: https://demo.testfire.net/login.jsp
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:

Description:
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

Quick Start | Request | Response | Requester

Header: Text | Body: Text

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Content Security Policy (CSP) Header Not Set

URL: https://demo.testfire.net/login.jsp
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:

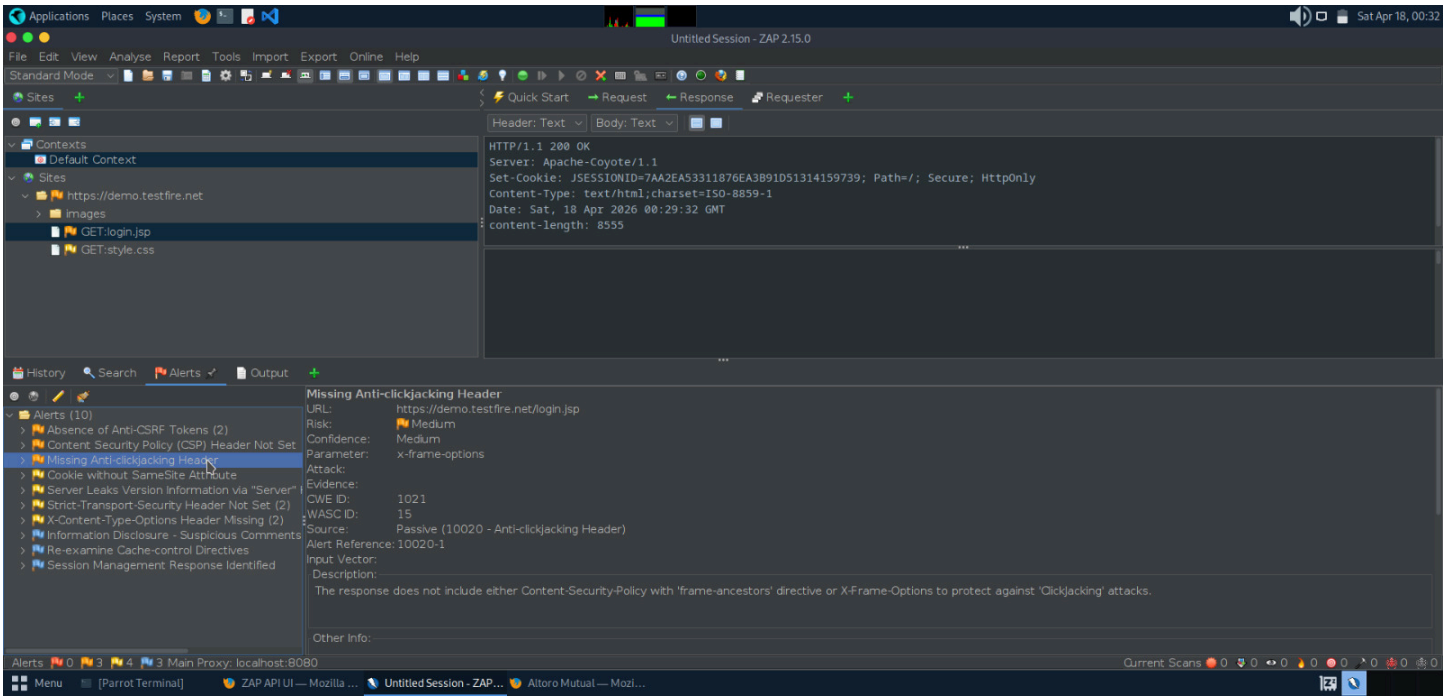
Description:

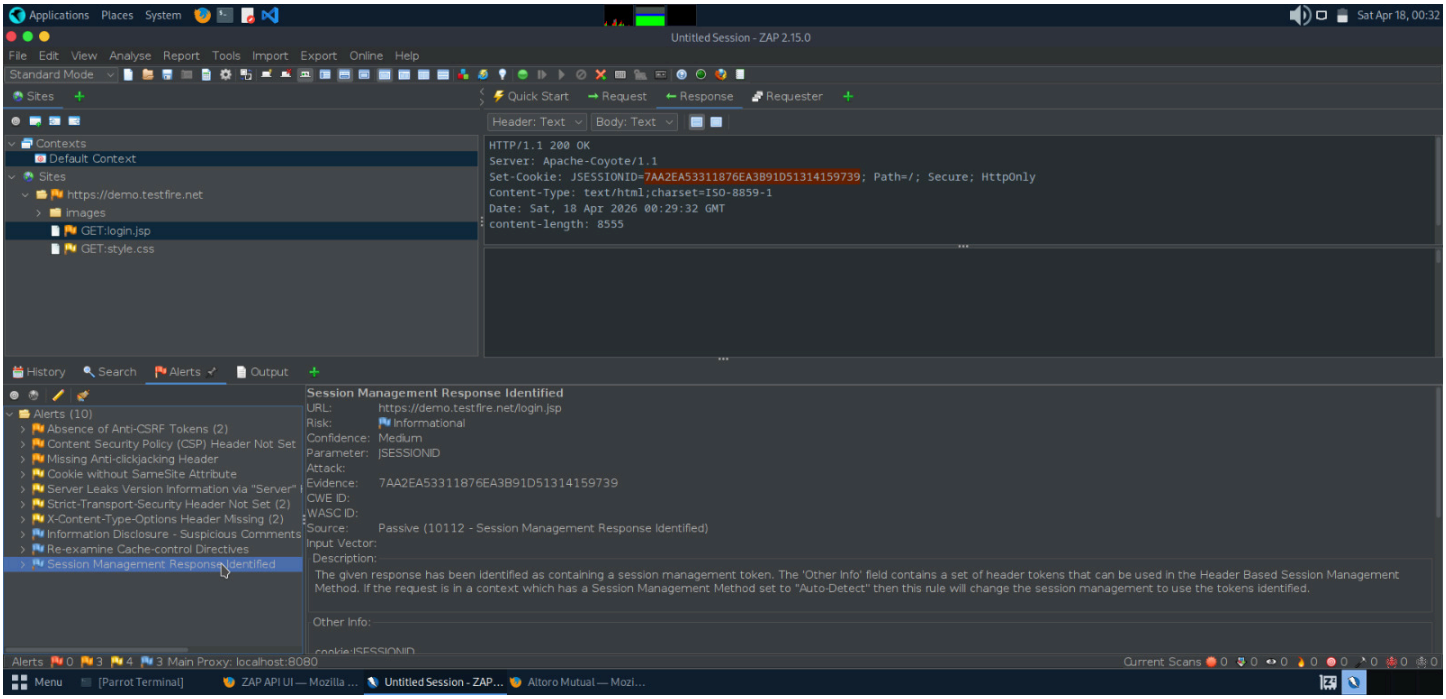
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...


Applications Places System
Sat Apr 18, 00:32
Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
https://demo.testfire.net
images
GET:login.jsp
GET:style.css
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
History
Search
Alerts
Output
Alerts (10)
Absence of Anti-CSRF Tokens (2)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header
Cookie without SameSite Attribute
Server Leaks Version Information via "Server"
Strict-Transport-Security Header Not Set (2)
X-Content-Type-Options Header Missing (2)
Information Disclosure - Suspicious Comments
Re-examine Cache-control Directives
Session Management Response Identified
Missing Anti-clickjacking Header
URL: https://demo.testfire.net/login.jsp
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
CWE ID: 1021
WASC ID: 15
Source: Passive (10020 - Anti-clickjacking Header)
Alert Reference: 10020-1
Input Vector:
Description:
The response does not include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options to protect against 'ClickJacking' attacks.
Other Info:
Alerts 0 3 4 3 Main Proxy: localhost:8080
Current Scans 0 0 0 0 0 0 0 0
Menu
[Parrot Terminal]
ZAP API UI — Mozilla ...
Untitled Session - ZAP...
Altoro Mutual — Mozi...


Applications Places System
Sat Apr 18, 00:32
Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
https://demo.testfire.net
images
GET:login.jsp
GET:style.css
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
History
Search
Alerts
Output
Alerts (10)
Absence of Anti-CSRF Tokens (2)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header
Cookie without SameSite Attribute
Server Leaks Version Information via "Server"
Strict-Transport-Security Header Not Set (2)
X-Content-Type-Options Header Missing (2)
Information Disclosure - Suspicious Comments
Re-examine Cache-control Directives
Session Management Response Identified
Session Management Response Identified
URL: https://demo.testfire.net/login.jsp
Risk: Informational
Confidence: Medium
Parameter: JSESSIONID
Attack:
Evidence: 7AA2EA53311876EA3B91D51314159739
CWE ID:
WASC ID:
Source: Passive (10112 - Session Management Response Identified)
Input Vector:
Description:
The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
Other Info:
Alerts 0 3 4 3 Main Proxy: localhost:8080
Current Scans 0 0 0 0 0 0 0 0
Menu
[Parrot Terminal]
ZAP API UI — Mozilla ...
Untitled Session - ZAP...
Altoro Mutual — Mozi...

5. Risk Classification Summary

Risk Level :	High	Medium	Low	Informational
Count :	3	4	4	2

6. Overall Recommendations

1.Enforce HTTPS across all endpoints

2.Implement complete security headers

3.Reduce exposed services and ports

4. Secure cookies and session management

5.Remove sensitive information from frontend code

6.Regularly scan using security tools

7.Apply secure coding best practices

7. Conclusion

* The assessment demonstrates that the target system contains multiple vulnerabilities across network, application, and client layers.

* Although the application is intentionally vulnerable for testing, these findings mirror real-world risks such as:

1. Data interception

2.Unauthorized access

3.Client-side attacks

4. Full system compromise

Addressing these issues will significantly enhance security posture and resilience in any production-grade system.